

Multi-Stage Intrusion: Reconnaissance to Exfiltration

Report ID	IR-2026-KC01	Classification	Internal / Portfolio
Analyst	William James	Severity	High
Environment	Detection lab	Status	Closed / documented

Portfolio note: this report documents a staged intrusion in a controlled home detection lab. Each detection referenced is real work from the author's existing repositories; simulated stages are labelled as such and no results are fabricated.

1 Executive Summary

A single threat actor operating from host **192.168.64.15** executed a complete intrusion against the lab environment, progressing through five kill-chain stages: reconnaissance, initial access, foothold and command-and-control, lateral movement, and data exfiltration. The activity was independently detected at three telemetry layers host, network, and cloud SIEM and reconstructed into a single correlated timeline.

The intrusion began with a TCP SYN scan, escalated to an SSH brute-force that compromised valid credentials, established a foothold via an obfuscated PowerShell payload with periodic C2 beaconing, then moved laterally and exfiltrated data over a covert channel. Because the same activity surfaced across multiple independent detection layers, no single blind spot concealed it, a direct demonstration of defense-in-depth value.

Primary impact: loss of credential confidentiality and subsequent data exfiltration (Confidentiality), with attacker remote control of an endpoint (Integrity). Response actions contained the host, invalidated compromised credentials, blocked the C2 destination, and recommended network segmentation to close the lateral-movement path.

2 Methodology

The investigation followed a structured seven-step process to identify, establish a theory, test the theory, plan, implement, verify, and document the same discipline used for network troubleshooting, applied to incident response. Evidence was gathered before conclusions were drawn, hypotheses were confirmed with telemetry before any action was taken, and every stage was corroborated across independent log sources rather than trusted from a single vantage point.

Detection spanned three layers: host telemetry (Wazuh, Sysmon, and PowerShell Script Block Logging shipped to Splunk), network telemetry (Suricata IDS with custom signatures), and cloud SIEM (Microsoft Sentinel KQL hunts). Correlation across these sources produced the unified kill-chain timeline presented in Section 3.

3 Findings — Kill-Chain Timeline

Stage	Attacker Action	Detection Layer	CIA	ATT&CK
1. Reconnaissance	TCP SYN port scan enumerating open services	Network Suricata sid 1000001	Precursor	T1046
2. Initial Access	SSH brute-force; valid credentials compromised	Host + Network + Cloud	Confidentiality	T1110
3. Foothold / C2	Obfuscated PowerShell payload; periodic beacon	Host (Sysmon EID1 / 4104) + Cloud	Integrity + Conf.	T1059.001

Stage	Attacker Action	Detection Layer	CIA	ATT&CK
4. Lateral + Exfil	SMB/RDP fan-out; data exfil over covert channel	Cloud SIEM + SPL correlation	Confidentiality	T1021 / T1048
5. Impact / Close	Exfiltration achieved; investigation and response	Correlated across all layers	—	—

Note: Suricata rule sid 1000002 also fired on the network layer for the Stage 2 brute-force; the Wazuh host rule chain (5760–40112) escalated to a level-12 compromise alert; the Sentinel hunt confirmed the pattern (88 failed logins, 8 successes) at the cloud layer.

4 Indicators of Compromise

Type	Indicator	Context
Source IP	192.168.64.15	Attacker host (Kali) — all offensive activity
Technique	SYN scan (nmap -sS)	Stage 1 reconnaissance
Auth pattern	88 failed / 8 success (SSH)	Stage 2 brute-force signature
Event ID	Sysmon EID 1; PowerShell 4104	Stage 3 execution / deobfuscation
Behaviour	Periodic C2 beacon	Stage 3 command-and-control
Behaviour	SMB/RDP fan-out; DNS anomalies	Stage 4 lateral movement / exfil

Lab-assigned host IPs (JAMES-VM, Ubuntu target) and exact timestamps to be finalised from lab evidence before publication.

5 Response & Recommendations

Immediate containment

Isolate the compromised endpoint (disable its switch port), preserve volatile evidence (active connections and owning processes via netstat), and invalidate the compromised credentials.

Eradication & recovery

Block the C2 destination at the perimeter, remove the PowerShell foothold and any persistence, and verify no residual beaconing before returning the host to service.

Hardening recommendations

Implement network segmentation so lateral movement is forced through a logged Layer-3 chokepoint rather than travelling silently east-west; enforce MFA and rate limiting on SSH to blunt brute-force; and extend DNS monitoring to catch tunneling based on query volume and subdomain entropy.

6 Conclusion

The intrusion was fully reconstructed by correlating host, network, and cloud telemetry into a single kill-chain narrative. The exercise demonstrates that individual detections become far more powerful when stitched into one investigation: the analyst's value lies not in any single rule firing, but in connecting signals across layers into a coherent story with attributable indicators and a defensible response.

Full technical detail, per-stage detection evidence, and mappings to both MITRE ATT&CK and the underlying networking fundamentals are available in the project repository.

